Semana 02 — Instrumentar las operaciones criptograficas

Grupo 3 · rol Púrpura · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	02 de 10
Fase	1 — Fundamentos, criptografía y marco legal
Grupo	3
Rol	Púrpura
Entrega	GitHub, carpeta semana_02/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Instrumenta la detección del mismo evento: activa el registro, define la alerta y mide lo que se habría visto, incluidos los falsos positivos y negativos.

- Instrumentar el evento, activando el registro que lo vería y definiendo la alerta con su umbral.
- Comparar lo que se registró con lo que se ejecutó, ítem por ítem del paso a paso.
- Reportar falsos positivos y negativos y proponer el ajuste concreto de la regla.

2 Qué aporta este rol al entregable

La regla o consulta de detección y la tabla de lo detectado frente a lo ejecutado.

3 Ejemplo paso a paso

El rol Púrpura no cifra por cifrar: define que señal deberia quedar registrada, ejecuta la operacion y comprueba que el registro permite reconstruirla sin exponer secretos.

3.1 Envolver las operaciones y registrar solo metadatos

El registro guarda operacion, marca de tiempo, identificador de clave y resultado. Nunca la clave, el nonce completo ni el texto claro.

```
mkdir -p semana_02/evidencia
cat > semana_02/registro.py <<'PY'
import json, sys, time
from cryptography.hazmat.primitives.ciphers.aead import AESGCM
import os

def registrar(operacion, clave_id, resultado):
    linea = {"ts": time.time(), "op": operacion,
             "clave_id": clave_id, "resultado": resultado}
    with open('semana_02/evidencia/cripto.jsonl', 'a') as fh:
        fh.write(json.dumps(linea) + "\n")

clave = AESGCM.generate_key(bit_length=256)
nonce = os.urandom(12)
datos = open('semana_02/evidencia/mensaje.bin', 'rb').read()
AESGCM(clave).encrypt(nonce, datos, None)
registrar('aes-gcm-cifrar', 'clave-01', 'ok')
try:
    AESGCM(clave).decrypt(nonce, datos, None)
    registrar('aes-gcm-cifrar', 'clave-01', 'ok')
except Exception:
    registrar('aes-gcm-cifrar', 'clave-01', 'error')
PY
python3 semana_02/registro.py
```

3.2 Medir reutilizacion de nonce en cien cifrados

Repetir un nonce con la misma clave rompe GCM por completo. El script genera cien nonces y verifica que no se repite ninguno; el resultado va al registro.

```
python3 - <<'PY' | tee semana_02/evidencia/nonces.txt
import os
nonces = [os.urandom(12) for _ in range(100)]
print('total', len(nonces))
print('unicos', len(set(nonces)))
print('reutilizados', len(nonces) - len(set(nonces)))
PY
```

3.3 Buscar material criptografico expuesto

Se buscan claves privadas y cadenas con alta entropia en el arbol y en el historial. La deteccion mira el repositorio, no solo los archivos del informe.

```
git grep -nE 'BEGIN (RSA|OPENSSH|EC|PRIVATE) PRIVATE KEY' \
  | tee semana_02/evidencia/secretos.txt || true
git grep -nEi '(api[_-]?key|token)[[:space:]]*=[[:space:]]*[A-Za-z0
    -9/+]{20,}' \
  >> semana_02/evidencia/secretos.txt || true
```

3.4 Señal, fuente y umbral de alerta

Señal, fuente y umbral de alerta

Senal	Fuente	Registro	Umbral	Accion
Cifrado fallido	Envoltorio de AESGCM	cripto.jsonl resultado error	Mas de 3 en 5 minutos	Revisar clave y nonce
Nonce repetido	Generador de 100 cifrados	nonces.txt reutilizados	Cualquier valor mayor que 0	Rotar clave de inmediato
Clave privada en repo	git grep en arbol e historial	secretos.txt	Cualquier coincidencia	Retirar, rotar y avisar
KDF por debajo del objetivo	Medicion de tiempos	pbkdf2.txt	Menos de 0,2 s	Subir iteraciones

El umbral se declara antes de medir; si se ajusta despues de ver el resultado, se anota el cambio y el motivo.

4 Qué guardar en el repositorio

El informe presenta el envoltorio, un extracto del registro JSONL y la tabla de señales con su umbral, ademas de la busqueda de material expuesto.

```
semana_02/
|-- informe.md
|-- registro.py
|-- evidencia/
|   |-- cripto.jsonl
|   |-- nonces.txt
|   `-- secretos.txt
`-- README.md
```

- El registro no contiene claves, nonces completos ni texto claro.
- La comprobacion de nonces se ejecuta y su salida esta en evidencia/.

- Cada señal tiene un umbral declarado y una accion asociada.
- La busqueda de secretos incluye el historial de git.

5 Cómo se corrige

Criterio	Peso
Cifrado y descifrado correctos con verificación de integridad	3,0
Firma y verificación demostradas, incluido el caso alterado	2,5
Lectura correcta del certificado y de la cadena	2,0
Medición de KDF con conclusión sobre coste y seguridad	1,5
Explicación de qué propiedad cubre cada primitiva	1,0
Total	**10,0**

- {'Registrar metadatos de una operacion sensible tambien es dato personal': 'se limita a lo necesario.'}
- Un nonce de prueba no se reutiliza en produccion aunque el registro diga ok.

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.